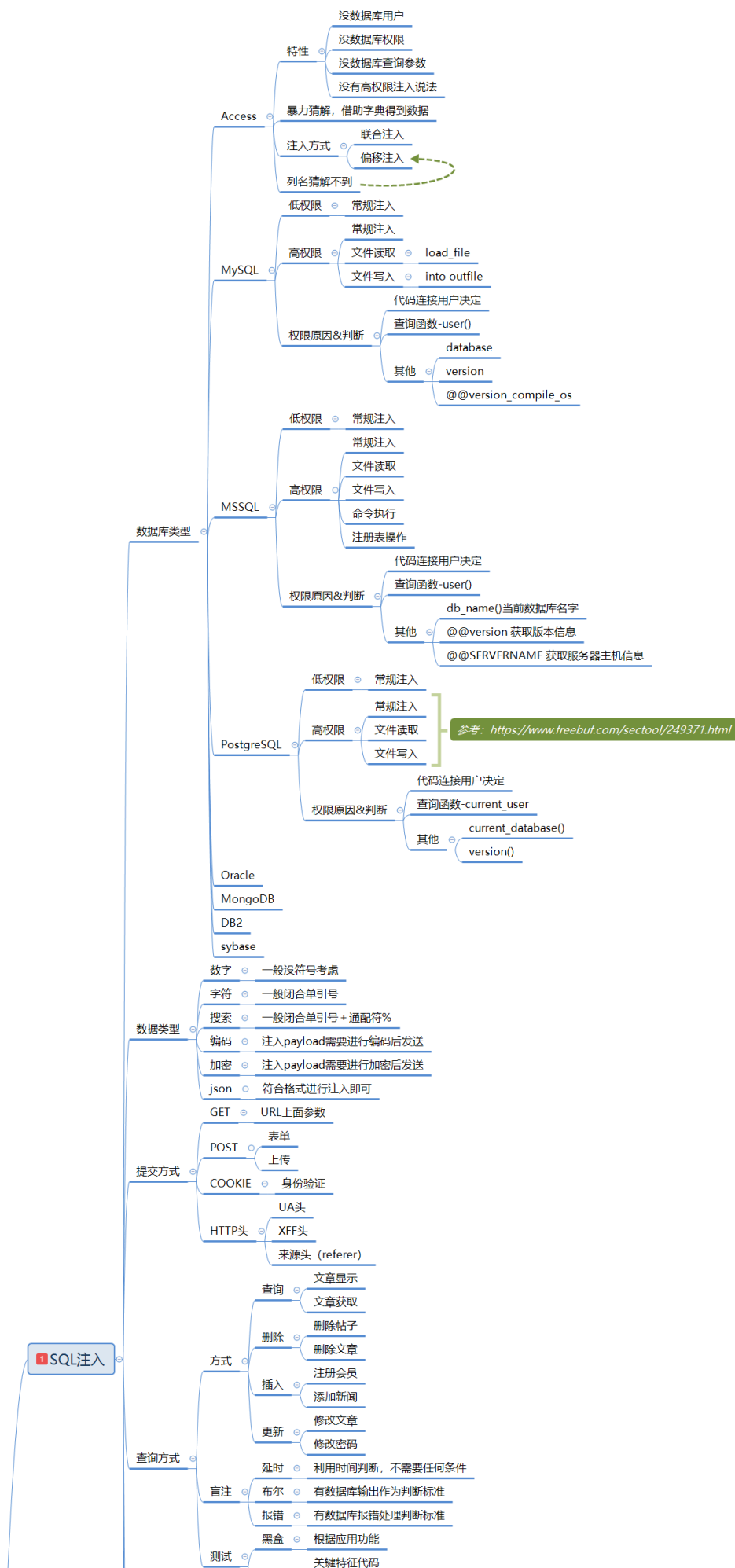
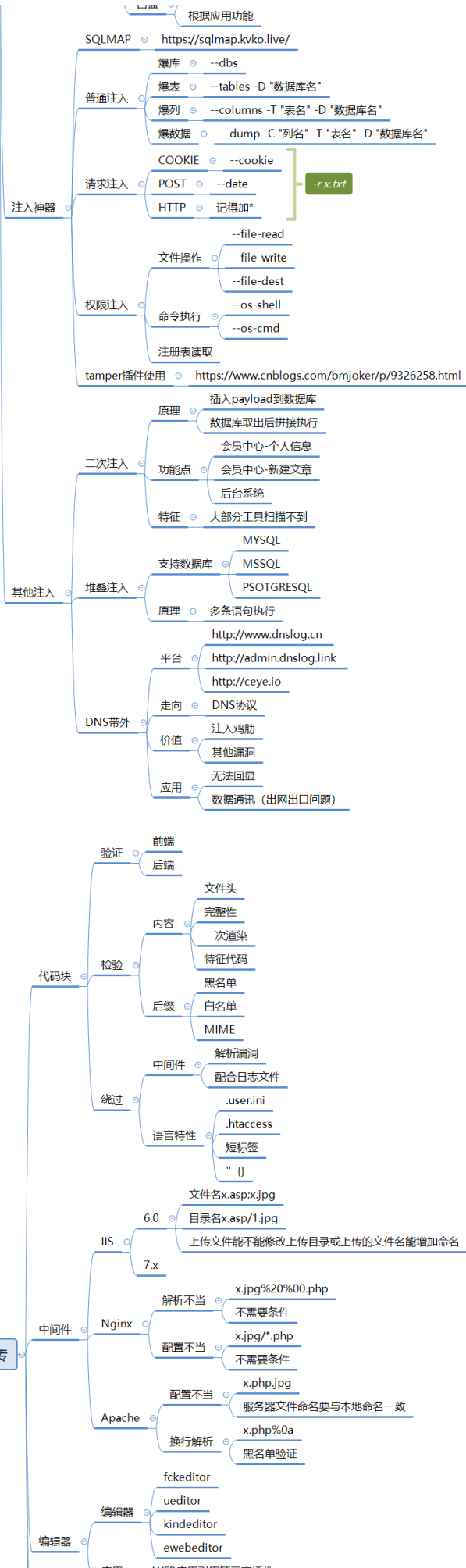
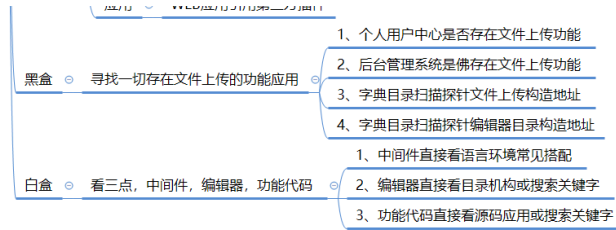


Day55 WEB攻防-XSS跨站&CSP策略 &HttpOnly属性&Filter过滤器&标签闭合&事件触 发



2 文件上传





通用安全漏洞

4 CSRF

-
- ```

graph LR
 A[条件] --> B[1、目标用户已经登录了网站，能够执行网站的功能。]
 A --> C[2、目标用户访问了攻击者构造的 URL。]
 C --> D[探针且防御]
 D --> E[1、看验证来源-修复]
 D --> F[2、看凭证有无 token-修复]
 D --> G[3、看关键操作有无验证-修复]
 E --> H[流程]
 H --> I[1、获取目标的触发数据包]
 H --> J[2、利用 CSRFTester 构造导出]
 J --> K[审计]
 K --> L[1、获取目标的触发数据包]
 K --> M[2、利用 CSRFTester 构造导出]

```
- 条件
- 1、目标用户已经登录了网站，能够执行网站的功能。
  - 2、目标用户访问了攻击者构造的 URL。
- 探针且防御
- 1、看验证来源-修复
  - 2、看凭证有无 token-修复
  - 3、看关键操作有无验证-修复
- 流程
- 1、获取目标的触发数据包
  - 2、利用 CSRFTester 构造导出
- 审计
- 1、获取目标的触发数据包
  - 2、利用 CSRFTester 构造导出

## 5 SSRF

- 条件
  - 当前功能应用点利用服务器去解析拟提交的资源
- 功能
  - 分享
  - 转码
  - 翻译
  - 图片加载
  - 收藏
  - 信息探针
  - 内网扫描

| 语言     | PHP                          | Java       | curl                     | Perl              | ASP.NET             |
|--------|------------------------------|------------|--------------------------|-------------------|---------------------|
| http   | ✓                            | ✓          | ✓                        | ✓                 | ✓                   |
| socket | with<br>cURL extensions      | jdk1.5.1_2 | before 7.40.0 不<br>支持SSL | ✓                 | before<br>version 3 |
| ftp    | cURL extensions              | ✓          | before 7.40.0 不<br>支持SSL | ✓                 | ✓                   |
| dns    | ✓                            | ✓          | ✓                        | ✓                 | ✓                   |
| file   | ✓                            | ✓          | ✓                        | ✓                 | ✓                   |
| imap   | with<br>cURL extensions      | ✓          | ✓                        | ✓                 | ✓                   |
| mysql  | with<br>cURL extensions      | ✓          | ✓                        | ✓                 | ✓                   |
| xml    | with<br>cURL extensions      | ✓          | ✓                        | ✓                 | ✓                   |
| smtp   | cURL extensions              | ✓          | ✓                        | ✓                 | ✓                   |
| ldap   | with<br>cURL extensions      | ✓          | ✓                        | ✓                 | ✓                   |
| url2   | 支持于<br>PHP4 and .Japan       | ✓          | ✓                        | 支持于<br>perl 5.005 | ✓                   |
| url3   | 支持于<br>PHP4 and .Japan       | ✓          | ✓                        | ✓                 | ✓                   |
| ldap3  | 支持于<br>perl 5.005 and .Japan | ✓          | ✓                        | ✓                 | ✓                   |
| php    | 支持于<br>PHP4 and .Japan       | ✓          | ✓                        | ✓                 | ✓                   |

- 探针且防御 ○ SSRF常见安全修复防御方案. ○
- 1、禁用跳转
  - 2、禁用不需要的协议
  - 3、固定或限制资源地址
  - 4、错误信息统一-信息处理

- ```

graph LR
    A[审计] --- B[SSRF白盒可能出现的地方]
    A --- C[SSRF黑盒可能出现的地方]
    B --- B1[1. 功能点抓包指向代码块审计]
    B --- B2[2. 功能点函数定位代码块审计]
    C --- C1[1. 社交分享功能]
    C --- C2[2. 转码服务]
    C --- C3[3. 在线翻译]
    C --- C4[4. 图片加载/下载]
    C --- C5[5. 图片/文章收藏功能]
    C --- C6[6. 云服务厂商]
    C --- C7[7. 网站采集, 网站抓取的地方]
    C --- C8[8. 数据库内置功能]
    C --- C9[9. 邮件系统]
    C --- C10[10. 编码处理, 属性信息处理, 文件处理]
    C --- C11[11. 未公开的api实现以及其他扩展调用URL的功能]
    C --- C12[12. 从远程服务器请求资源]
  
```

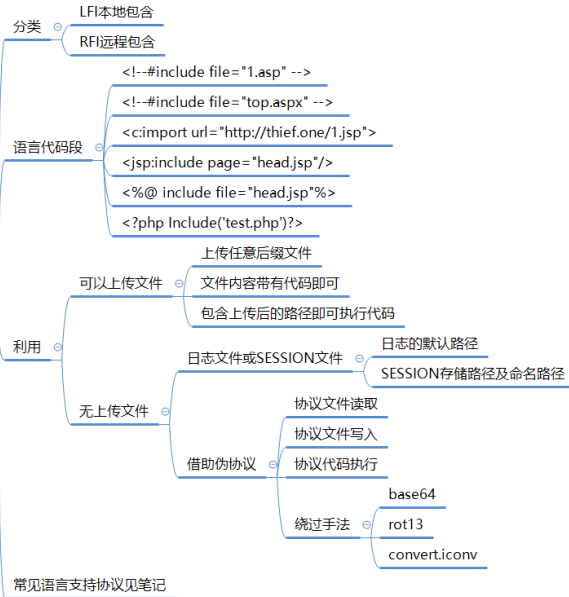
6 XXE&XML

- ```

graph LR
 Root[前置] --- A[理由：传输和存储数据]
 Root --- B[危害：文件读取，端口探针等]
 Root --- C[Content-Type]
 Root --- D[黑盒]
 Root --- E[白盒]
 Root --- F[有回显]
 Root --- G[无回显]
 Root --- H[伪协议玩法]
 Root --- I[禁用dtd实体引用]
 Root --- J[过滤关键词：<!DOCTYPE和<!ENTITY，或者SYSTEM和PUBLIC]
 D --- D1[数据格式]
 D --- D2[svg&excel引用]
 E --- E1[1、可通过应用功能追踪代码定位审计]
 E --- E2[2、可通过脚本特定函数搜索定位审计]
 E --- E3[3、可通过伪协议玩法绕过相关修复等]
 F --- F1[file读取文件]
 F --- F2[http带外访问]
 G --- G1[file读取文件-先读取]
 G --- G2[http带外访问-加载实体]
 G --- G3[dtd实体带外访问-将数据参数发送接收文件接收数据处理]
 H --- H1[见笔记图，后期文件包含会讲]

```

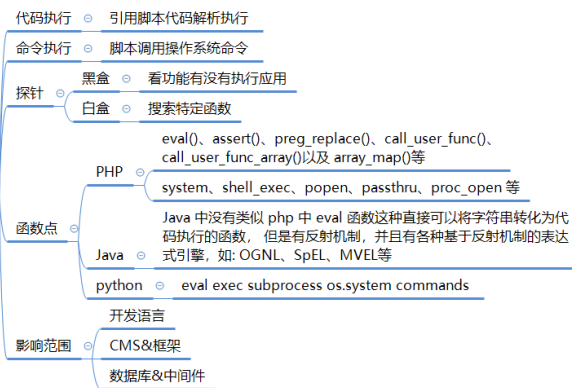
## 文件包含



## 其他文件操作安全



## RCE



## PHP



## 反序列化

### JAVA

#### 属性

- `__toString()`: 把类当做字符串使用时触发
- `__sleep()`: `serialize()` 函数会检查类中是否存在一个魔术方法 `__sleep()` 如果存在, 该方法会被优先调用
- `public` (公共的): 在本类内部、外部类、子类都可以访问
- `protect` (受保护的): 只有本类或子类或父类中可以访问
- `private` (私人的): 只有本类内部可以使用
  - 序列化数据显示:
    - `private` 属性序列化的时候格式是 `%00 类名%00 成员名`
    - `protect` 属性序列化的时候格式是 `%00*%00 成员名`

#### 利用

- 单纯的魔术方法逻辑调用
- PHP 语言的特性漏洞-如 CVE-2016-7124
- 魔术方法内置原生类
  - 1、获取魔术方法对应原生类
  - 2、利用原生类官方说明配合
- 字符串逃逸 & Phar
  - 后面专题讲到

#### 原理

- 序列化: 把 Java 对象转换为字节序列的过程。
- 反序列化: 把字节序列恢复为 Java 对象的过程。

#### 发现

- Serializable Externalizable 接口、fastjson、jackson、gson、ObjectInputStream.read、ObjectObjectInputStream.readUnshared、XMLDecoder.read、ObjectYaml.loadXStream.fromXML、ObjectMapper.readValue、JSON.parseObject 等
- 功能
  - http 参数, cookie, session, 存储方式可能是 base64(r00), 压缩后的 base64(H4s), MII 等。Servlets http, Sockets, Session 管理器, 包含的协议就包括 JMX, RMI, JMS, JNDI 等 (xac \Xed) xmlstream, XmlDecoder 等 (http Body: Content-type: application/xml) json (jackson fastjson) http 请求中包含
- 数据特性
  - 一段数据以 r00AB 开头, 你基本可以确定这串就是 JAVA 序列化 base64 加密的数据。
  - 或者如果以 aced 开头, 那么他就是这一段 java 序列化的 16 进制。

#### 利用

- Ysoserial
  - 无组件
  - 有组件
- 特定的组件利用
  - shiro
  - jboos

### Python

#### 解释

- 文件 & 字符串 & 字节流 & 对象相互转换的过程

#### 原理

- 序列化调用魔术方法
- 反序列化调用魔术方法

#### 函数 & 魔术方法

- 函数使用:
  - `pickle.dump(obj, file)`: 将对象序列化后保存到文件
  - `pickle.load(file)`: 读取文件, 将文件中的序列化内容反序列化为对象
  - `pickle.dumps(obj)`: 将对象序列化成字符串格式的字节流
  - `pickle.loads(bytes_obj)`: 将字符串格式的字节流反序列化为对象
- 魔术方法:
  - `__reduce__()` 反序列化时调用
  - `__reduce_ex__()` 反序列化时调用
  - `__setstate__()` 反序列化时调用
  - `__getstate__()` 序列化时调用

#### 利用

- 注意当前构造版本和目标版本对应
- 注意当前是否需要编码、转换等

#### 白盒

- 搜索特定函数
- 使用 bandit

### 访问权限

#### 越权

- 水平同级用户
  - 用户信息获取时未对用户与 ID 比较判断直接查询等
- 垂直低高用户
  - 数据库中用户类型编号接受篡改或高权限操作未验证等

#### 访问控制

- 验证丢失
  - 未包含引用验证代码文件等
- 没有验证
  - 支持空口令、匿名、白名单等

#### 脆弱验证

- Cookie
  - JWT
  - Session
- 不安全的验证逻辑等

### 购买支付

#### 安全点

- 价格和数量
- 产品和订单编号
- 支付模式 & 接口数据
- 折扣优惠券积分等重复使用 & 再获取

#### 安全问题

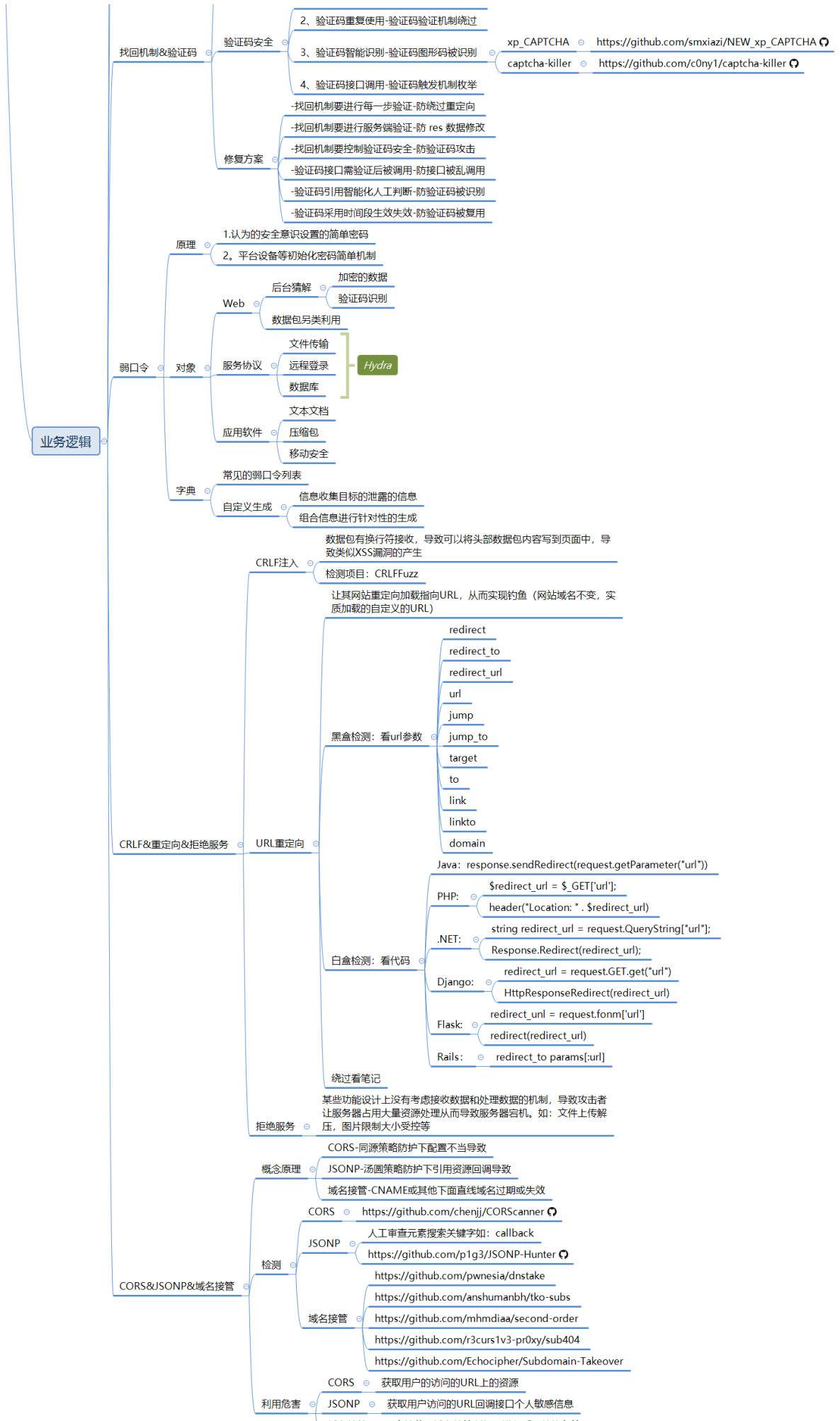
- 1、商品购买-数量 & 价格 & 编号等
- 2、支付模式-状态 & 接口 & 负数等
- 3、折扣处理-优惠券 & 积分 & 重放等

#### 挖掘 & 修复

- 1、金额以数据库定义为准
  - 2、购买数量限制为正整数
  - 3、优惠券固定使用后删除
  - 4、订单生成后检测对应值
- 功能点抓包造代码测试

#### 找回机制

- 1、用回显状态判断-res 前端判断不安全
- 2、用用户名重定向-修改标示绕过验证
- 3、验证码回显显示-验证码泄漏验证虚设
- 4、验证码简单机制-验证码过于简单爆破





## 1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库漏洞下载
- 3、ASP-IIS-CVE&短文件&解析&写入

- 
- 1、PHP-MYSQL-SQL注入-常规查询
  - 2、PHP-MYSQL-SQL注入-跨库查询
  - 3、PHP-MYSQL-SQL注入-文件读写

- 
- 1、PHP-MYSQL-SQL注入-数据请求类型
  - 2、PHP-MYSQL-SQL注入-数据请求方法
  - 3、PHP-MYSQL-SQL注入-数据请求格式

- 
- 1、PHP-MYSQL-SQL注入-方式增删改查
  - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
  - 3、PHP-MYSQL-SQL注入-数据回显&报错处理

- 
- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
  - 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
  - 3、PHP-MYSQL-SQL注入-带外注入&利用条件

- 
- 1、注入工具-SQLMAP-常规猜解&字典配置
  - 2、注入工具-SQLMAP-权限操作&文件命令
  - 3、注入工具-SQLMAP-Tamper&使用&开发
  - 4、注入工具-SQLMAP-调试指纹&风险等级

- 
- 1、PHP-原生态-文件上传-检测后缀&黑白名单
  - 2、PHP-原生态-文件上传-检测信息&类型内容
  - 3、PHP-原生态-文件上传-函数缺陷&逻辑缺陷
  - 4、PHP-原生态-文件上传-版本缺陷&配置缺陷

- 
- 1、PHP-中间件-文件上传-CVE&配置解析

- 2、PHP-编辑器-文件上传-第三方引用安全
- 3、PHP-CMS源码-文件上传-已知识别到利用

- 
- 1、文件上传-安全解析方案-目录权限&解码还原
  - 2、文件上传-安全存储方案-分站存储&OSS对象

- 
- 1、文件包含-原理&分类&危害-LFI&RFI
  - 2、文件包含-利用-黑白盒&无文件&伪协议

- 
- 1、文件安全-前后台功能点-下载&读取&删除
  - 2、目录安全-前后台功能点-目录遍历&目录穿越

- 
- 1、XSS跨站-输入输出-原理&分类&闭合
  - 2、XSS跨站-分类测试-反射&存储&DOM

- 
- 1、XSS跨站-攻击利用-凭据盗取
  - 2、XSS跨站-攻击利用-数据提交
  - 3、XSS跨站-攻击利用-网络钓鱼
  - 4、XSS跨站-攻击利用-溯源综合

- 
- 1、XSS跨站-安全防御-CSP策略
  - 2、XSS跨站-安全防御-HttpOnly
  - 3、XSS跨站-安全防御-XSSFilter

---

## 2.演示案例

### 2.1 XSS跨站-安全防御-CSP



- 1 1. CSP (Content Security Policy 内容安全策略)
- 2 内容安全策略是一种可信白名单机制，来限制网站中是否可以包含某来源内容。
- 3 该制度明确告诉客户端，哪些外部资源可以加载和执行，等同于提供白名单，
- 4 它的实现和执行全部由浏览器完成，开发者只需提供配置。
- 5 禁止加载外域代码，防止复杂的攻击逻辑。
- 6 禁止外域提交，网站被攻击后，用户的数据不会泄露到外域。
- 7 禁止内联脚本执行（规则较严格，目前发现 **GitHub** 使用）。
- 8 禁止未授权的脚本执行（新特性，**Google Map** 移动版在使用）。
- 9 合理使用上报可以及时发现XSS，利于尽快修复问题。



- 1 实验:
- 2 开启CSP时XSS的加载情况
- 3 未开启CSP时XSS的加载情况
- 4 绕过: 有但鸡肋
- 5 <https://xz.aliyun.com/t/12370>
- 6 <https://blog.csdn.net/a1766855068/article/details/89370320>
- 7 `header("Content-Security-Policy:img-src 'self' ");`

## 2.2 XSS跨站-安全防御-HttpOnly



- 1 2. HttpOnly
- 2 禁止页面的JavaScript访问带有HttpOnly属性的Cookie。
- 3 PHP.INI设置或代码引用
- 4 `-session.cookie_httponly =1`
- 5 `-ini_set("session.cookie_httponly", 1);`
- 6 `-setcookie(' ', ' ', time() + 3600, '/xss', ' ', false, true);`



- 1 实验:
- 2 开启HttpOnly时XSS窃取Cookie的加载情况
- 3 未开启HttpOnly时XSS窃取Cookie的加载情况
- 4 绕过: 有但鸡肋
- 5 (1) CVE-2012-0053
- 6 (2) PHPINFO页面/
- 7 (3) Flash/Java
- 8 [https://blog.csdn.net/weixin\\_42478365/article/details/116597222](https://blog.csdn.net/weixin_42478365/article/details/116597222)
- 9 思路: 不获取Cookie采用方式(钓鱼, 浏览器攻击框架等)

## 2.3 XSS跨站-安全防御-XSSFilter



- 1 3. XSS Filter
- 2 检查用户输入的数据中是否包含特殊字符, 如<、>、'、",进行实体化等。



- 1 实验: 手工分析&工具分析
- 2 Xss-Lab 标签及常见过滤绕过
- 3 环境下载: <https://github.com/Re130rn/xss-lab>
- 4 参考资料: <https://xz.aliyun.com/t/4067>
- 5 工具资料: <https://github.com/s0md3v/XSSStrike>
- 6 1、无任何过滤
- 7 `<script>alert()</script>`
- 8
- 9 2、实体化 输入框没有
- 10 `"> <script>alert()</script> <"`

```
11
12 3、全部实体化 利用标签事件 单引号闭合
13 ' onfocus=javascript:alert() '
14
15 4、全部实体化 利用标签事件 双引号闭合
16 " onfocus=javascript:alert() "
17
18 5、事件关键字过滤 利用其他标签调用 双引号闭合
19 "> xxx <"
20
21 6、利用大小写未正则匹配
22 "> <script>alert()</script> <"
23
24 7、利用双写绕过匹配
25 "> x <"
26
27 8、利用Unicode编码
28 javascript:alert()
29
30 9、利用Unicode编码（内容检测）
31 javascript:alert()('http://')
32
33 10、隐藏属性触发闭合
34 ?t_sort=" onfocus=javascript:alert() type="text
35
36 11-20
37 https://blog.csdn.net/12872253606/article/details/125638898
```

- 
- 1 黑盒XSS手工分析：
  - 2 1、页面中显示的数据找可控的（有些隐藏的）
  - 3 2、利用可控地方发送JS代码去看执行加载情况
  - 4 3、成功执行即XSS，不能成功就看语句输出的地方显示（过滤）
  - 5 4、根据显示分析为什么不能执行（实体化，符号括起来，关键字被删除等）